Documento de Concepção de Projeto: API de Detecção de Fraudes em E-commerce

1. Identificação do Projeto

- **Nome do Projeto:** SecurePay AI - API de Prevenção a Fraudes
- **Disciplina:** Tópicos Especiais
- **Integrantes do Grupo (Até 4 pessoas):**
    - Caio Leonel Oliveira Rosa
    - [Nome do Integrante 2]
    - [Nome do Integrante 3]
    - [Nome do Integrante 4]

2. Informações do Negócio

Visão Geral: O ecossistema de e-commerce sofre anualmente com perdas massivas devido a transações fraudulentas, chargebacks e roubo de credenciais. O projeto *SecurePay AI* consiste no desenvolvimento de um microsserviço focado na análise de risco de transações financeiras em tempo real. A aplicação atua como um intermediário entre a loja virtual e o gateway de pagamento, avaliando o comportamento e os dados da compra para atribuir um "Score de Risco".
Objetivo Principal: Minimizar a aprovação de compras fraudulentas sem prejudicar a experiência de usuários legítimos (redução de falsos positivos), garantindo alta disponibilidade e tempo de resposta inferior a 200ms por requisição para não impactar o checkout da loja.

3. Regras de Negócio (RN)

Código	Descrição da Regra	Criticidade
RN01	Toda transação com Score de Risco acima de 85 (em uma escala de 0 a 100) deve ser automaticamente bloqueada e o status da compra atualizado para "Cancelada".	Alta
RN02	Transações com Score de Risco entre 70 e 84 devem ser retidas no status "Em Análise" para validação manual por um analista de fraude ou confirmação via 2FA pelo cliente.	Média
RN03	O sistema deve rejeitar imediatamente transações cujo país de origem do IP (geolocalização) seja diferente do país de emissão do cartão de crédito, exceto se houver aviso prévio de viagem no perfil do usuário.	Alta
RN04	É expressamente proibido o armazenamento do CVV (Código de Verificação) do cartão de crédito em banco de dados ou logs, em conformidade com as	Crítica

Código	Descrição da Regra	Criticidade
	normas internacionais PCI-DSS.	

4. Arquitetura de Segurança de Acesso

A segurança da informação é um pilar estrutural do microsserviço, operando em múltiplas camadas para proteger endpoints da API e os dados sensíveis trafegados.

- **Autenticação de Máquina-para-Máquina (Lojas e Gateways):** O acesso aos endpoints da API de análise só será permitido a clientes de e-commerce previamente cadastrados. A autenticação será realizada utilizando OAuth 2.0 (fluxo *Client Credentials*) com emissão de tokens JWT (JSON Web Tokens) assinados com algoritmo RS256 e tempo de expiração curto (15 minutos).
- **Criptografia de Dados:** Todos os dados em trânsito deverão trafegar obrigatoriamente sob protocolo TLS 1.3 (HTTPS). Dados sensíveis em repouso no banco de dados, como os números mascarados de cartões de crédito (PANs), serão criptografados utilizando o algoritmo AES-256.
- **Proteção de Infraestrutura e Endpoints:** O sistema implementará um mecanismo de *Rate Limiting* para limitar o número de requisições por segundo provenientes de um mesmo IP ou Lojista, mitigando ataques de Negação de Serviço (DDoS) e força bruta. Também haverá sanitização rigorosa de entradas para prevenir injeções de código (SQL Injection / NoSQL Injection).
- **Controle de Acesso Baseado em Papéis (RBAC) - Painel Web:** O painel administrativo terá papéis definidos:
    - *Admin:* Acesso total às configurações do sistema, cadastro de novos e-commerces e gerência de chaves de API.
    - *Analista de Fraude:* Acesso restrito ao dashboard de transações suspeitas e permissão unicamente para aprovar ou negar manualmente transações retidas pela regra RN02.

5. Utilização da Inteligência Artificial

A Inteligência Artificial atua como o motor central de tomada de decisão. Diferente de sistemas baseados inteiramente em regras "Se-Então" (que se tornam rapidamente obsoletos e fáceis de

burlar), a IA consegue identificar padrões complexos de cibercriminosos.

5.1. Técnica e Abordagem

O projeto empregará um modelo de **Machine Learning (Aprendizado Supervisionado)** para classificação, como um algoritmo de Floresta Aleatória (*Random Forest*) ou *XGBoost*. Esse modelo deve ser treinado utilizando grandes volumes de bases de dados históricas (datasets) contendo amostras rotuladas de transações legítimas e transações fraudulentas confirmadas.

5.2. Dados de Entrada do Modelo (Features)

Para a IA calcular o risco, a API fornecerá as seguintes informações no momento do checkout:

- **Dados do Dispositivo e Conexão:** Endereço IP (para geolocalização e verificação se é de uma rede proxy/VPN conhecida), *device fingerprint*, e fuso horário.
- **Padrão de Comportamento:** Velocidade de preenchimento do formulário da loja (bots preenchem dados em frações de segundo) e o horário da compra em relação ao histórico comum daquele cliente.
- **Dados da Transação:** Valor total da compra, divergência de CEPs (endereço de cobrança vs. endereço de entrega) e o tipo de produto (fraudes costumam visar produtos de alta liquidez como smartphones e gift cards).

5.3. Saída do Modelo de IA

O modelo processará os dados em tempo real e retornará para a aplicação backend:

- **Probabilidade de Fraude (Score):** Um número de 0 a 100 indicando o risco estatístico calculado para a transação em andamento.
- **Reason Codes (Explicabilidade):** Uma lista de fatores que mais contribuíram para o aumento do Score (Ex: "Distância anormal entre IP e CEP de entrega"), permitindo que o Analista de Fraude entenda o raciocínio da IA antes de tomar uma decisão sobre os casos retidos.